

WEB APPLICATION SECURITY ASSESSMENT

**Comprehensive Analysis on MyITS
Iptek Web Application**

Dosen Pengampu :

Bekti Cahyo Hidayanto, S.Si., M.Kom.

Izzat Aulia Akbar, S.Kom., M.Eng., Ph.D.

Dimas Agung Perkasa, S.Kom., M.Kom.

OUR TEAM



M. HAMMAM ADITAMA

5026231179



DAVIN JONATHAN T.

5026231131



RIAN CHAIRUL ICHSAN

5026231121



DANIEL SANDI B.

5026231216



CLAY AMSAL S.H.

5026231132

DAFTAR ISI

DAFTAR ISI.....	3
BAB I PENDAHULUAN.....	5
1.1 Latar Belakang.....	5
1.2 Rumusan Masalah.....	6
1.3 Tujuan.....	6
1.4 Manfaat.....	7
BAB II DASAR TEORI.....	8
2.1 Website Iptek ITS (Open Journal Systems).....	8
2.1.1 Gambaran Umum OJS (Open Journal Systems).....	8
2.1.2 Fitur Registrasi & Login Pengguna.....	8
2.1.3 Fitur Pencarian Jurnal (Search).....	8
2.1.4 Fitur Unggah Naskah (Submission).....	9
2.2 SEO Spamming & Journal Jacking.....	9
2.3 Broken Access Control.....	9
2.4 Cross-Site Scripting (XSS).....	10
2.5 SQL Injection (SQLi).....	10
2.6 Information Gathering & Reconnaissance.....	10
2.7 Penetration Testing.....	10
BAB III METODOLOGI.....	11
3.1 Information Gathering & Reconnaissance.....	11
3.1.1 Google Dorking (Passive Recon).....	11
3.1.2 Whois & DNS Lookup.....	11
3.1.3 Pemeriksaan Robots.txt & Sitemap.....	11
3.2 Port Scanning (Nmap).....	12
3.2.1 Basic Scan & Service Version.....	12
3.2.2 Aggressive Scan.....	13
3.3 Directory Scanning.....	14
3.3.1 Langkah Pengerjaan.....	15
3.4 Vulnerability Scanning.....	17
3.5 Broken Access Control Testing.....	17
3.6 SEO Spam Detection.....	18
3.6.1 Langkah Pengerjaan.....	18
3.6.2 Kesimpulan Eksplorasi Pengerjaan SEO Spam Detection.....	20

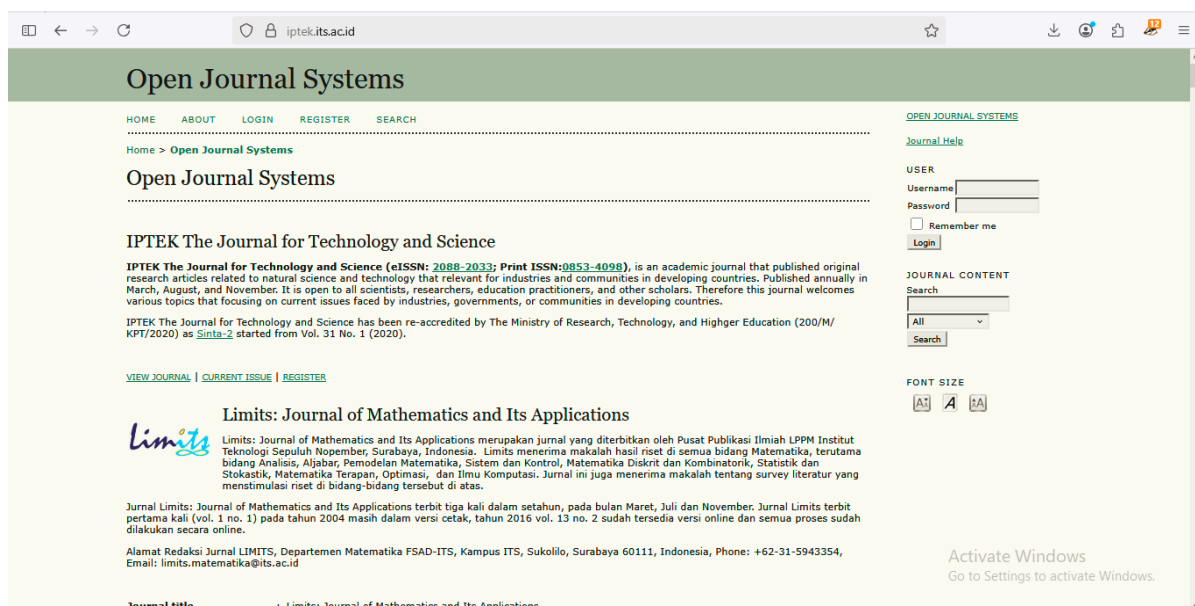
BAB IV HASIL DAN PEMBAHASAN.....	21
4.1 Hasil Reconnaissance.....	21
4.2 Hasil Port Scanning (Nmap).....	23
4.2.1 Hasil Basic Scan & Service Version.....	23
4.2.2 Hasil Agressive Scan.....	24
4.3 Hasil Directory Scanning (Gobuster).....	25
4.3.1 Hasil Enumerasi Direktori.....	25
4.3.2 Analisis Perbandingan Wordlist.....	27
4.3.3 Identifikasi Platform (Fingerprinting).....	27
4.3.4 Analisis Temuan Kritis dan Validasi Manual.....	28
4.3.5 Hasil Enumerasi Rekursif (Recursive Scanning).....	29
4.4 Analisis Celah Keamanan Aplikasi.....	31
4.4.1 Temuan SEO Spam pada Metadata Jurnal.....	31
4.4.2 Analisis Versi OJS (Outdated Version).....	33
4.4.3 Pengujian Halaman Login.....	35
BAB V KESIMPULAN DAN SARAN.....	38
5.1 Kesimpulan.....	38
5.2 Saran.....	38
DAFTAR PUSTAKA.....	40

BAB I

PENDAHULUAN

1.1 Latar Belakang

Institut Teknologi Sepuluh Nopember (ITS) sebagai institusi pendidikan tinggi terkemuka memiliki kewajiban untuk memfasilitasi diseminasi hasil penelitian ilmiah. Portal iptek.its.ac.id merupakan infrastruktur vital yang dikelola oleh Lembaga Penelitian dan Pengabdian kepada Masyarakat (LPPM) ITS untuk menaungi berbagai jurnal ilmiah, mulai dari bidang teknik, sains, hingga sosial humaniora. Platform ini menggunakan Open Journal Systems (OJS), sebuah perangkat lunak manajemen jurnal berbasis open-source yang dikembangkan oleh Public Knowledge Project (Public Knowledge Project, 2024).



Gambar 1.1 Tampilan Halaman Utama Portal Jurnal iptek.its.ac.id

Di era transformasi digital, integritas platform publikasi ilmiah menjadi aset informasi yang sangat berharga. Namun, berdasarkan observasi awal, portal jurnal ini masih menggunakan versi OJS lawas (Legacy OJS 2.x) pada beberapa jurnalnya, meskipun sebagian lain sedang dalam proses migrasi ke OJS 3. Penggunaan perangkat lunak yang tidak diperbarui (outdated software) sering kali membawa kerentanan keamanan yang telah diketahui publik atau Publicly Known Vulnerabilities (OWASP Foundation, 2021).

Urgensi dari penilaian keamanan ini didasari oleh adanya temuan anomali pada metadata publik beberapa jurnal di dalam portal tersebut. Teridentifikasi adanya penyisipan konten ilegal berupa kata kunci perjudian daring (online gambling keywords) atau SEO Spam pada deskripsi jurnal, seperti yang terlihat pada "Jurnal Aplikasi Teknik Sipil" dan "Journal of Infrastructure & Facility Asset Management".

Insiden ini, yang sering disebut sebagai Journal Jacking atau Defacement, tidak hanya mengancam ketersediaan layanan, tetapi juga merusak reputasi akademik institusi di mata mesin pencari atau Search Engine Reputation (Sucuri, 2023). Oleh karena itu, Laporan Tugas Akhir mata kuliah Proteksi Aset Informasi ini disusun untuk melakukan Vulnerability Assessment dan Penetration Testing secara etis terhadap iptek.its.ac.id. Tujuannya adalah untuk mengidentifikasi celah keamanan yang dieksploitasi oleh peretas, menganalisis dampaknya, serta merumuskan strategi mitigasi untuk memulihkan integritas aset informasi ITS.

1.2 Rumusan Masalah

Berdasarkan latar belakang di atas, rumusan masalah yang akan dibahas dalam laporan ini adalah:

1. Bagaimana postur keamanan portal iptek.its.ac.id ditinjau dari aspek kerentanan aplikasi web (OWASP Top 10)?
2. Celah keamanan apa yang menyebabkan terjadinya injeksi konten SEO Spam (judi online) pada metadata jurnal ITS?
3. Bagaimana langkah mitigasi yang tepat untuk membersihkan sistem dari konten berbahaya dan mencegah serangan serupa di masa depan?

1.3 Tujuan

Berdasarkan rumusan masalah tersebut, tujuan pada penelitian penetration testing terhadap iptek.its.ac.id adalah sebagai berikut:

1. Mengidentifikasi celah keamanan pada platform Open Journal Systems (OJS) yang digunakan oleh iptek.its.ac.id, terutama terkait penggunaan versi perangkat lunak yang lawas.
2. Mendeteksi keberadaan konten ilegal atau malicious injection (seperti SEO Spam judi online) yang telah menyusup ke dalam metadata jurnal.
3. Memberikan rekomendasi perbaikan (mitigation plan) yang konkret untuk membersihkan sistem dari konten berbahaya dan mencegah serangan serupa di masa mendatang.

1.4 Manfaat

Berdasarkan tujuan penelitian di atas, adapun manfaat dari kegiatan dan penyusunan laporan ini antara lain:

1. Membantu pengelola sistem iptek.its.ac.id dalam mengetahui letak kelemahan sistem yang selama ini tidak terdeteksi.
2. Memulihkan reputasi akademik ITS dengan memberikan panduan pembersihan konten judi online yang mencemari hasil pencarian jurnal di Google.
3. Menjadi referensi teknis bagi administrator dalam melakukan hardening server dan migrasi ke versi OJS yang lebih aman.
4. Mengimplementasikan pemahaman mahasiswa terkait materi Vulnerability Assessment dan etika profesi dalam melakukan pengujian keamanan siber.

BAB II

DASAR TEORI

2.1 Website Iptek ITS (Open Journal Systems)

Website iptek.its.ac.id merupakan portal jurnal elektronik yang dikelola oleh Institut Teknologi Sepuluh Nopember (ITS). Portal ini dibangun di atas platform Open Journal Systems (OJS), yang memungkinkan pengelolaan alur kerja editorial secara digital dan terpusat.

2.1.1 Gambaran Umum OJS (Open Journal Systems)

Open Journal Systems (OJS) adalah perangkat lunak manajemen jurnal dan penerbitan berbasis web yang bersifat sumber terbuka (open source), dikembangkan oleh Public Knowledge Project (PKP). OJS dirancang untuk mengurangi energi klerikal dan manajerial yang terkait dengan penyuntingan jurnal, sekaligus meningkatkan nilai pencatatan dan pengindeksan jurnal (Public Knowledge Project, 2024).

Platform ini dibangun menggunakan bahasa pemrograman PHP dan menggunakan basis data MySQL atau PostgreSQL sebagai penyimpanannya. Karena popularitasnya yang tinggi di kalangan institusi pendidikan, OJS sering menjadi target serangan siber, terutama pada instalasi yang menggunakan versi lawas (seperti OJS 2.x) yang memiliki kerentanan keamanan yang telah diketahui publik (CVE Details, 2025).

2.1.2 Fitur Registrasi & Login Pengguna

Fitur ini merupakan gerbang utama bagi pengguna (penulis, reviewer, editor) untuk berinteraksi dengan sistem. Pada konfigurasi standar OJS versi lama, fitur registrasi sering kali bersifat terbuka (Open Registration) tanpa validasi CAPTCHA yang memadai. Kelemahan ini sering dieksploitasi oleh bot otomatis untuk mendaftarkan akun palsu secara massal (mass registration) yang kemudian digunakan untuk menyuntikkan konten spam atau malware ke dalam profil pengguna (PKP Docs, 2023).

2.1.3 Fitur Pencarian Jurnal (Search)

Fitur pencarian memungkinkan pengunjung situs untuk menemukan artikel berdasarkan judul, penulis, abstrak, atau kata kunci tertentu. Jika input pada kolom pencarian tidak disanitasi dengan benar (input sanitization), fitur

ini menjadi vektor serangan utama untuk Cross-Site Scripting (XSS) Reflected atau SQL Injection (PortSwigger, 2024).

2.1.4 Fitur Unggah Naskah (Submission)

Fitur submisi adalah fungsi inti OJS yang memungkinkan penulis mengunggah file naskah. Fitur Arbitrary File Upload menjadi risiko kritis jika sistem gagal memvalidasi ekstensi dan isi file yang diunggah, yang memungkinkan penyerang mengunggah web shell untuk mendapatkan akses kontrol penuh atau Remote Code Execution (OWASP Foundation, 2021).

2.2 SEO Spamming & Journal Jacking

SEO Spamming (atau spamdexing) adalah teknik manipulasi indeks mesin pencari dengan menyisipkan kata kunci atau tautan yang tidak relevan ke dalam sebuah situs web tanpa izin pengelola. Tujuannya adalah untuk mendongkrak peringkat situs pihak ketiga (biasanya situs judi atau produk ilegal) menggunakan reputasi domain target yang tinggi, seperti domain institusi pendidikan .ac.id.

Journal Jacking merupakan bentuk khusus dari serangan siber di dunia akademik di mana penyerang mengambil alih identitas, metadata, atau alamat web jurnal ilmiah resmi untuk tujuan penipuan. Dalam konteks Open Journal Systems (OJS), serangan ini sering terjadi pada versi perangkat lunak yang sudah usang (outdated) yang memiliki celah pada sistem validasi input metadata. Dampak utamanya adalah pencemaran hasil pencarian mesin pencari yang dapat merusak kredibilitas institusi di tingkat internasional.

2.3 Broken Access Control

Berdasarkan OWASP Top 10: 2021, Broken Access Control menempati peringkat pertama sebagai risiko keamanan aplikasi web yang paling kritis. Kerentanan ini terjadi ketika kebijakan yang membatasi akses pengguna tidak ditegakkan dengan benar oleh server. Dalam konteks OJS, kerentanan ini memungkinkan pengguna dengan hak akses rendah (seperti Author) untuk mengakses fitur administratif (OWASP Foundation, 2021).

2.4 Cross-Site Scripting (XSS)

Cross-Site Scripting (XSS) adalah jenis kerentanan injeksi di mana penyerang menyisipkan skrip berbahaya (biasanya JavaScript) ke dalam halaman web yang dilihat oleh pengguna lain (PortSwigger, 2024).

- Stored XSS: Skrip berbahaya disimpan secara permanen di server target (misalnya, di dalam kolom abstrak artikel).
- Reflected XSS: Skrip dipantulkan dari server web, biasanya melalui pesan error atau hasil pencarian.

2.5 SQL Injection (SQLi)

SQL Injection (SQLi) adalah teknik serangan injeksi kode yang memanfaatkan celah keamanan pada lapisan basis data aplikasi. Serangan ini terjadi ketika input pengguna yang tidak difilter dimasukkan langsung ke dalam kueri SQL dinamis. Celah ini memungkinkan penyerang untuk mem-bypass autentikasi atau mengambil data sensitif seperti password hash administrator (PortSwigger, 2024).

2.6 Information Gathering & Reconnaissance

Information Gathering atau Reconnaissance adalah tahap awal dan paling krusial dalam siklus Penetration Testing.

- Passive Reconnaissance: Mengumpulkan informasi tanpa berinteraksi langsung, misalnya menggunakan Google Dorking dan Whois (EC-Council, 2023).
- Active Reconnaissance: Melibatkan interaksi langsung seperti Port Scanning dengan Nmap.

2.7 Penetration Testing

Penetration Testing (uji penetrasi) adalah simulasi serangan siber yang sah dan terotorisasi terhadap sistem komputer untuk mengevaluasi tingkat keamanannya. Dalam laporan ini, metode yang digunakan adalah Black Box Testing, di mana penguji memposisikan diri sebagai penyerang eksternal yang tidak memiliki pengetahuan internal mengenai sistem (Imperva, 2024).

BAB III

METODOLOGI

3.1 Information Gathering & Reconnaissance

Tahap pertama dalam proses pengujian keamanan ini adalah pengumpulan informasi (Information Gathering) atau Reconnaissance. Tujuan dari tahap ini adalah untuk mendapatkan gambaran menyeluruh mengenai target iptek.its.ac.id tanpa melakukan interaksi intrusif yang dapat merusak sistem. Metode yang digunakan bersifat pasif (Passive Reconnaissance) dan semi-aktif.

3.1.1 Google Dorking (Passive Recon)

Metode ini memanfaatkan operator pencarian lanjutan (advanced search operators) pada mesin pencari Google untuk menemukan informasi sensitif atau anomali yang terindeks secara publik. Teknik ini sangat efektif untuk mendeteksi defacement, halaman login tersembunyi, atau file konfigurasi yang tidak sengaja terekspos. Query yang digunakan `site:iptek.its.ac.id "slot" OR "gacor" OR "judi"`. Tujuannya untuk memverifikasi apakah domain target telah disusupi oleh konten SEO Spam atau halaman phishing yang memanfaatkan reputasi domain akademik.

3.1.2 Whois & DNS Lookup

Whois Lookup dilakukan untuk mengidentifikasi informasi kepemilikan domain, penyedia hosting, tanggal kedaluwarsa domain, dan name server yang digunakan. Informasi ini penting untuk memetakan permukaan serangan (attack surface) dan memastikan bahwa pengujian dilakukan pada aset yang benar milik ITS. Tools yang digunakan: Layanan publik Whois (seperti who.is atau terminal command whois).

3.1.3 Pemeriksaan Robots.txt & Sitemap

Pemeriksaan file robots.txt dilakukan untuk mengetahui direktori mana saja yang diizinkan atau dilarang (disallow) oleh administrator untuk diindeks oleh mesin pencari (crawlers). File ini sering kali mengungkapkan struktur direktori tersembunyi atau area administratif (/admin, /login, /source) yang seharusnya tidak boleh diakses publik.

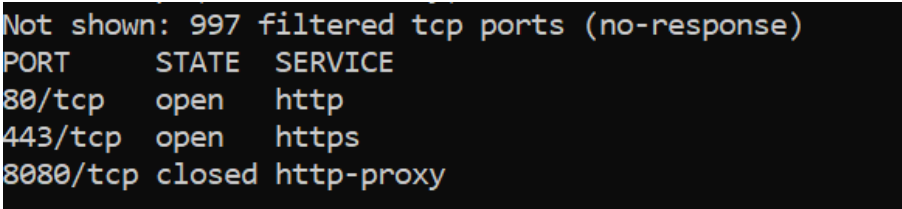
3.2 Port Scanning (Nmap)

Nmap (Network Mapper) diposisikan sebagai instrumen utama pada tahap *vulnerability scanning* untuk memetakan arsitektur keamanan pada domain <https://iptek.its.ac.id> Melalui mekanisme pengiriman paket data ke berbagai port jaringan, alat ini mampu mengidentifikasi status port yang terbuka, mendeteksi versi layanan (*service version*) yang sedang berjalan, hingga mengenali sistem operasi yang digunakan oleh server target. Informasi yang dihasilkan dari pemindaian ini sangat krusial karena menjadi fondasi bagi penguji untuk menentukan vektor serangan yang paling potensial, memastikan bahwa setiap celah keamanan diidentifikasi secara sistematis sebelum masuk ke tahap eksploitasi.

3.2.1 Basic Scan & Service Version

A. Basic Scan

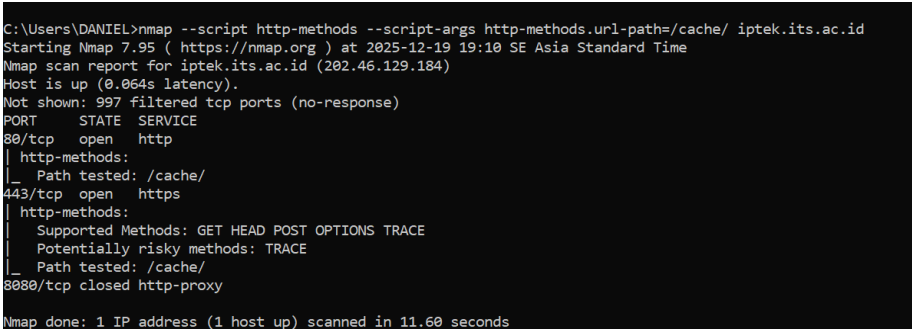
Sebagai langkah awal, dilakukan pemindaian port apa saja yang terbuka dengan **nmap -sS iptek.its.ac.id** dan didapatkan hasil:



```
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https
8080/tcp   closed http-proxy
```

Gambar 3.1 Eksekusi Perintah Basic Port Scanning Menggunakan Nmap

Hasil pemindaian menemukan direktori `/cache/` yang disembunyikan (*disallowed*). Pengujian lanjutan menggunakan skrip Nmap mengidentifikasi bahwa metode HTTP TRACE aktif, yang berpotensi disalahgunakan untuk serangan Cross-Site Tracing (XST).



```
C:\Users\DANIEL>nmap --script http-methods --script-args http-methods.url-path=/cache/ iptek.its.ac.id
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-19 19:10 SE Asia Standard Time
Nmap scan report for iptek.its.ac.id (202.46.129.184)
Host is up (0.064s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
|_ http-methods:
|_ Path tested: /cache/
443/tcp    open  https
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_ Path tested: /cache/
8080/tcp   closed http-proxy
Nmap done: 1 IP address (1 host up) scanned in 11.60 seconds
```

Gambar 3.2 Konfigurasi Perintah Aggressive Scan untuk Deteksi Versi dan OS

Terdapat method TRACE yang dimana cukup dapat disalah gunakan untuk XST(Cross Site Tracking)

B. Service Version

Setelah mendapatkan daftar port yang terbuka, dilakukan tahap selanjutnya yaitu service version detection. Pemindaian ini bertujuan untuk mengidentifikasi jenis layanan (service) beserta versinya yang berjalan di balik setiap port terbuka. Informasi ini penting untuk menilai potensi kerentanan spesifik dari layanan tersebut.

```
C:\Users\DANIEL>nmap -sV iptek.its.ac.id
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-19 19:40 SE Asia Standard Time
Nmap scan report for iptek.its.ac.id (202.46.129.184)
Host is up (0.097s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http   nginx 1.10.3
443/tcp    open  ssl/http nginx 1.10.3
8080/tcp   closed http-proxy
```

Gambar 3.3 Tampilan Output Terminal Hasil Identifikasi Layanan

Hasil pemindaian menunjukkan bahwa baik port 80 (HTTP) maupun 443 (HTTPS) dilayani oleh nginx 1.10.3.

- Nginx versi 1.10.3 adalah versi yang sangat usang (dirilis sekitar tahun 2017). Versi ini memiliki daftar kerentanan keamanan (CVE) yang panjang, termasuk celah *integer overflow* pada modul range filter.
- Meskipun Nginx terdeteksi di permukaan, halaman "Forbidden" sebelumnya menampilkan Apache/2.2.15. Ini membuktikan bahwa Nginx bertindak sebagai Reverse Proxy di depan server backend Apache yang juga sudah usang.
- Penyerang memiliki dua target sekaligus, mengeksploitasi Nginx di layer luar atau mencoba melakukan *request smuggling* untuk menyerang Apache di layer dalam.

3.2.2 Aggressive Scan

Tahap berikutnya adalah aggressive scan yang merupakan opsi lanjutan Nmap. Dimana tahap ini mendeteksi service dan os sekaligus serta melihat traceroute untuk mengetahui jaringan menuju server


```

... not shown: 557 filtered tcp ports (no response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    nginx 1.10.3
_ http-server-header: nginx/1.10.3
443/tcp   open  ssl/http nginx 1.10.3
_ ssl-date: TLS randomness does not represent time
_ tls-alpn:
_ http/1.1
_ http-server-header: nginx/1.10.3
_ ssl-cert: Subject: commonName=*.its.ac.id/organizationName=Insti
Subject Alternative Name: DNS:*.its.ac.id, DNS:its.ac.id
Not valid before: 2025-04-19T00:00:00
Not valid after: 2026-05-18T23:59:59
_ tls-nextprotoneg:
_ http/1.1
_ http-robots.txt: 1 disallowed entry
_ /cache/
_ http-title: Open Journal Systems
8080/tcp   closed http-proxy
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X (97%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
Aggressive OS guesses: Linux 3.11 - 4.9 (97%), Linux 3.2 - 3.8 (92
88%), Linux 4.19 - 5.15 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 10 hops

TRACEROUTE (using port 8080/tcp)
Hop RTT ADDRESS
1 5.00 ms 10.30.244.186
...
3 74.00 ms 114.0.212.33
...
7 79.00 ms 114-0-124-187.resources.indosat.com (114.0.124.187)
8 82.00 ms 114.9.20.12
...
9

```

Gambar 3.4 Eksekusi Perintah Gobuster CLI untuk Enumerasi Direktori

Hasil pemindaian agresif menunjukkan bahwa target menggunakan sistem operasi berbasis Linux (estimasi kernel 3.11 - 5.15) dengan jarak jaringan sebesar 10 *hops* dari titik pengujian. Infrastruktur web server teridentifikasi menggunakan nginx 1.10.3 yang melayani port 80 (HTTP) dan port 443 (HTTPS), di mana pada port 443 ditemukan penggunaan sertifikat SSL yang valid untuk domain *.its.ac.id hingga Mei 2026. Temuan krusial pada tahap ini mencakup adanya miskonfigurasi Information Disclosure di mana server membocorkan versi spesifik perangkat lunak yang sudah usang (*outdated*), serta adanya direktori `/cache/` yang terdeteksi melalui file `robots.txt` dan penggunaan sistem manajemen konten Open Journal Systems. Selain itu, pemindaian skrip mengonfirmasi bahwa port 443 mendukung metode HTTP TRACE, yang secara teknis dikategorikan sebagai metode berisiko karena potensinya dalam memfasilitasi serangan *Cross-Site Tracing* (XST).

3.3 Directory Scanning

Directory scanning didefinisikan sebagai metode brute-force terhadap struktur URL untuk mengidentifikasi keberadaan direktori dan file yang tidak dipublikasikan secara eksplisit (*unlinked contents*). Teknik ini bekerja dengan mengirimkan serangkaian permintaan HTTP (HTTP Requests) berdasarkan basis data kata (*wordlist*) yang telah ditentukan, kemudian menganalisis kode status HTTP (HTTP Status Codes) yang dikembalikan oleh server untuk menentukan keberadaan sumber daya tersebut.

Pada implementasinya terhadap target `https://iptek.its.ac.id`, pengujian dilakukan menggunakan *tools* Gobuster versi CLI (*Command Line Interface*). Pemilihan Gobuster didasarkan pada efisiensinya dalam menangani *concurrent requests* menggunakan bahasa pemrograman Go. Perintah eksekusi dikonfigurasi dengan parameter berikut:

```
gobuster dir -u https://iptek.its.ac.id/ -w common.txt -t 50
```

Parameter `-t 50` diterapkan untuk mengoptimalkan efisiensi waktu pemindaian melalui eksekusi 50 permintaan secara paralel (*concurrent threads*). Pada pengujian ini, konfigurasi filter tambahan, seperti pengecualian panjang respons (*length exclusion*) tidak diperlukan karena server target memberikan respons kode status HTTP (200, 301, dan 403) yang konsisten dan standar. Stabilitas respons ini mengindikasikan penggunaan teknologi server-side konvensional berbasis PHP, yang memungkinkan proses identifikasi validitas direktori dilakukan secara akurat langsung berdasarkan kode status yang diterima tanpa memerlukan penyesuaian filter lanjutan.

3.3.1 Langkah Pengerjaan

Pelaksanaan *directory scanning* dilakukan melalui pendekatan bertingkat (*multi-stage approach*) untuk menyeimbangkan efisiensi waktu dan kedalaman hasil pencarian. Tahapan ini memanfaatkan dua jenis basis data kata (*wordlist*) yang bersumber dari repositori standar industri keamanan, SecLists, dengan rincian prosedur sebagai berikut:

1. Persiapan Basis Data Kata (*Wordlist Preparation*)

Pemilihan *wordlist* menjadi faktor krusial dalam keberhasilan enumerasi. Pada penelitian ini, digunakan dua varian *wordlist* utama:

- Common.txt digunakan untuk fase pemindaian awal. Daftar ini memuat kata-kata yang paling sering digunakan sebagai nama direktori pada konfigurasi web server standar.
- directory-list-2.3-big.txt (dari koleksi DirBuster) digunakan untuk fase pemindaian mendalam. Daftar ini memiliki cakupan yang jauh lebih luas dan komprehensif, bertujuan untuk menemukan direktori yang menggunakan penamaan tidak standar atau jarang digunakan.

2. Enumerasi Tingkat Awal (*Initial Enumeration*)

Proses dimulai dengan menjalankan Gobuster menggunakan *wordlist* *common.txt*. Tujuan tahap ini adalah untuk mendapatkan gambaran cepat (*quick wins*) mengenai struktur utama aplikasi web dan mengidentifikasi direktori standar seperti */admin*, */login*, atau */uploads*.

```
=====
[+] Url:                https://iptek.its.ac.id/
[+] Method:             GET
[+] Threads:            50
[+] Wordlist:            C:\Users\Public\Documents\5\PAI\FP\common.txt
[+] Negative Status codes: 404
[+] User Agent:          gobuster/3.8.2
[+] Timeout:            10s
```

Gambar 3.5 Hasil Enumerasi Direktori Tahap Awal Menggunakan Wordlist Common

3. Enumerasi Tingkat Lanjut (*Deep Enumeration*)

Setelah pemindaian awal selesai, dilakukan pemindaian lanjutan menggunakan *wordlist* berskala besar, yaitu *directory-list-2.3-big.txt*. Tahap ini ditujukan untuk mendeteksi direktori tersembunyi yang tidak terdeteksi pada pemindaian awal, termasuk folder konfigurasi spesifik atau direktori aplikasi lawas (*legacy*) yang mungkin tertinggal di server.

```
PS C:\Users\Rian Chairul Ichsan> gobuster dir -u https://iptek.its.ac.id/ -w C:\Users\Public\Documents\5\PAI\SecLists-master\SecLists-master\Discovery\Web-Content\DirBuster-2007_directory-list-2.3-big.txt -t 50
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                https://iptek.its.ac.id/
[+] Method:             GET
[+] Threads:            50
[+] Wordlist:            C:\Users\Public\Documents\5\PAI\SecLists-master\SecLists-master\Discovery\Web-Content\DirBuster-2007_directory-list-2.3-big.txt
[+] Negative Status codes: 404
[+] User Agent:          gobuster/3.8.2
[+] Timeout:            10s
```

Gambar 3.6 Hasil Enumerasi Direktori Tahap Lanjut Menggunakan Wordlist Big

4. Identifikasi Aset Kritis dan Pemindaian Rekursif Hasil dari kedua tahap enumerasi di atas kemudian dianalisis untuk menentukan direktori yang dianggap "menarik" atau mencurigakan (*suspicious endpoints*), seperti direktori yang mengindikasikan panel administrasi (misalnya */dbadmin*), folder *tools*, atau direktori yang mengembalikan kode status 403 (Forbidden) namun berpotensi memiliki sub-direktori terbuka.

Terhadap direktori-direktori terpilih tersebut, dilakukan proses pemindaian rekursif (*recursive scanning*). Pada tahap ini, Gobuster dijalankan kembali dengan menargetkan URL sub-direktori spesifik (contoh: *https://iptek.its.ac.id/dbadmin/*) menggunakan *wordlist* *common.txt*. Langkah ini bertujuan untuk memetakan isi dari direktori tersebut guna mencari celah

keamanan lebih lanjut, seperti *unprotected file upload* atau *information disclosure*.

3.4 Vulnerability Scanning

Metodologi pemindaian kerentanan dilakukan melalui teknik inspeksi manual terhadap aplikasi web guna mengidentifikasi kelemahan pada komponen perangkat lunak yang digunakan oleh portal iptek.its.ac.id. Langkah-langkah yang dilakukan meliputi:

- Banner Grabbing & Header Analysis: Melakukan analisis manual terhadap header respons HTTP untuk mengidentifikasi informasi versi perangkat lunak server seperti Apache/2.2.15, Nginx/1.10.3, dan PHP/5.3.3. Prosedur ini bertujuan untuk menemukan penggunaan komponen usang (*outdated*) yang memiliki catatan kerentanan kritis atau CVE.
- Inspeksi Versi Platform (OJS): Meninjau kode sumber HTML sisi klien secara manual untuk mengidentifikasi versi platform Open Journal Systems (OJS) 2.4.2.0 melalui tag *meta-generator*.
- Audit Pustaka JavaScript (Third-party Libraries): Memeriksa versi pustaka JavaScript yang dimuat oleh aplikasi, seperti jQuery 1.4.4 dan jQuery UI 1.8.6, guna mencocokkannya dengan basis data kerentanan publik untuk mengetahui potensi celah keamanan seperti Cross-Site Scripting (XSS).

3.5 Broken Access Control Testing

Pengujian kontrol akses dilakukan untuk mengevaluasi efektivitas sistem dalam membatasi akses data sensitif dan manajemen sesi pengguna. Prosedur yang dilakukan meliputi:

- Manajemen Sesi dan Atribut Cookie: Melakukan inspeksi manual terhadap *cookie* sesi utama (OJSSID) melalui konsol pengembang peramban untuk memverifikasi ketersediaan flag keamanan *HttpOnly* dan *Secure*.
- Evaluasi Keamanan Formulir (CSRF): Meninjau kode sumber pada mekanisme pengiriman data, khususnya pada formulir login dan pencarian, untuk memastikan keberadaan token Anti-CSRF. Langkah ini menguji apakah sistem dapat mencegah manipulasi permintaan dari pihak ketiga yang tidak sah.
- Audit Eksposur Informasi Internal: Melakukan pencarian manual di dalam kode sumber aplikasi untuk menemukan potensi kebocoran data teknis yang

bersifat privat, seperti alamat IP internal 192.168.10.10 (Private IP Disclosure), serta mencoba akses langsung ke direktori sensitif melalui teknik *forced browsing*.

3.6 SEO Spam Detection

SEO Spam Detection merupakan tahapan krusial dalam identifikasi keberadaan konten berbahaya yang disisipkan ke dalam portal jurnal iptek.its.ac.id. Proses ini bertujuan untuk mendeteksi teknik Journal Jacking yang memanfaatkan otoritas domain institusi untuk mempromosikan situs eksternal melalui manipulasi metadata dan link hijacking.

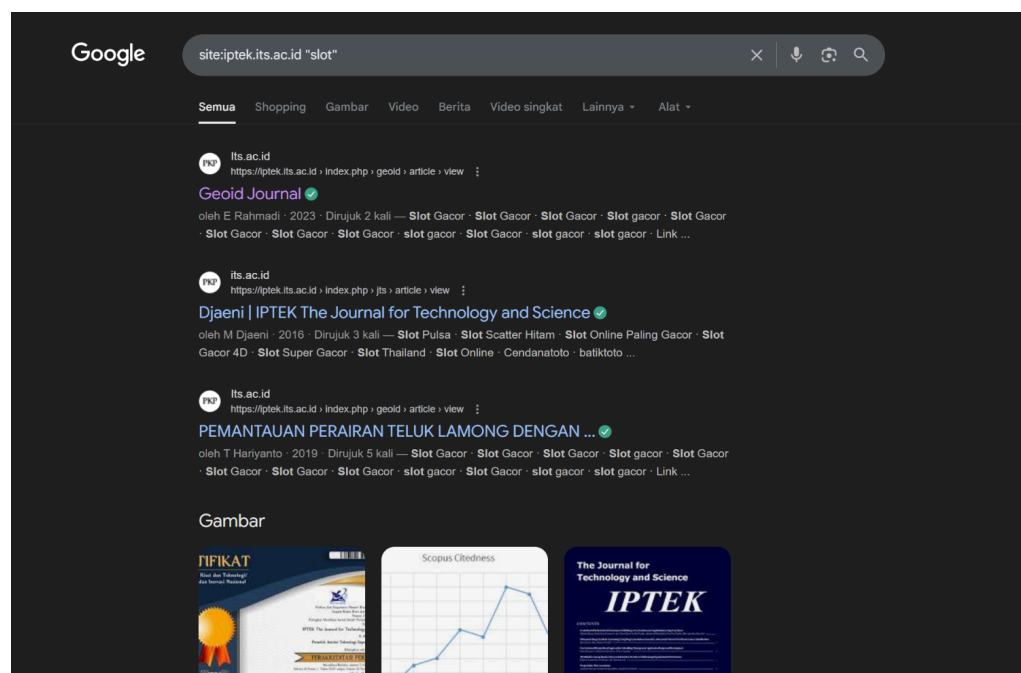
3.6.1 Langkah Pengerjaan

Proses deteksi dilakukan dengan mengkombinasikan teknik passive reconnaissance dan inspeksi teknis langsung pada kode sumber aplikasi.

A. Google Dorking (Passive Reconnaissance)

Langkah awal dilakukan dengan menggunakan operator pencarian Google untuk melihat bagaimana mesin pencari mengindeks halaman portal target. Commandnya adalah `site:iptek.its.ac.id "slot"` Langkah-langkahnya sebagai berikut:

1. Membuka mesin pencari Google.
2. Menjalankan perintah dorking di atas untuk memfilter halaman di domain iptek.its.ac.id yang mengandung kata kunci judi.
3. Menganalisis snippet atau cuplikan hasil pencarian yang ditampilkan.



Gambar 3.7 Hasil Google Dorking

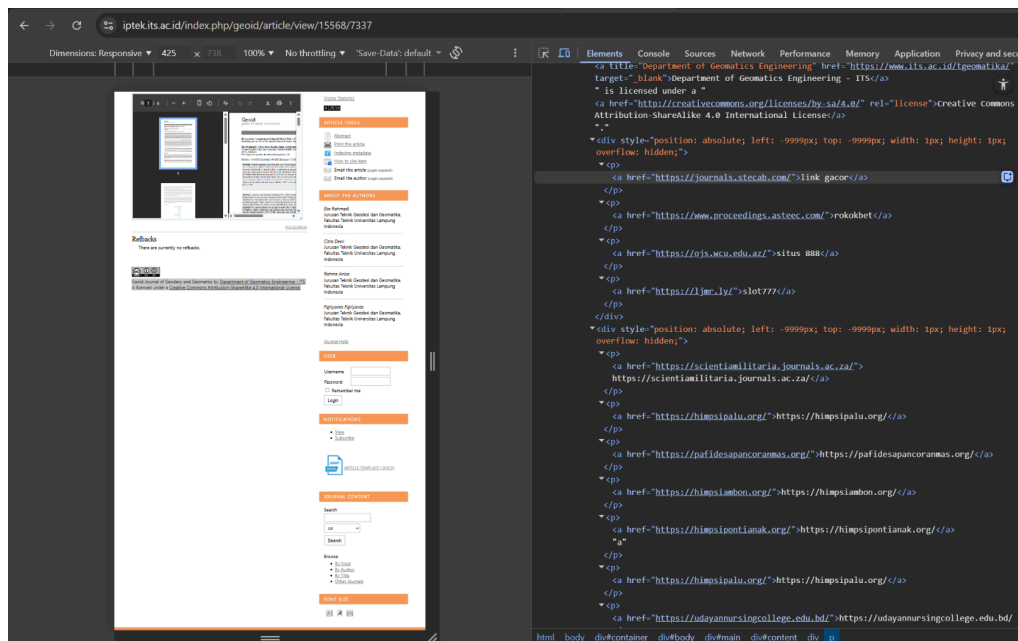
Berdasarkan hasil pencarian, ditemukan bahwa berbagai artikel pada Geoid Journal dan banyak artikel lainnya telah terindeks dengan kata kunci yang sangat tidak relevan seperti "Slot Gacor", "Slot Scatter Hitam", dan "Slot Thailand". Hal ini membuktikan bahwa penyerang telah berhasil memanipulasi metadata yang dibaca oleh mesin pencari.

B. Source Code Inspection (Active Inspection)

Untuk menemukan metode teknis penyembunyian konten, dilakukan pemeriksaan langsung pada halaman artikel yang terindikasi melalui fitur pengembang browser pada URL <https://iptek.its.ac.id/index.php/geoid/article/view/15568/7337>.

Langkah-langkahnya sebagai berikut:

1. Mengakses halaman artikel target di browser.
2. Klik kanan pada area halaman dan pilih Inspect Element (F12).
3. Mencari elemen yang menggunakan teknik cloaking atau manipulasi CSS.

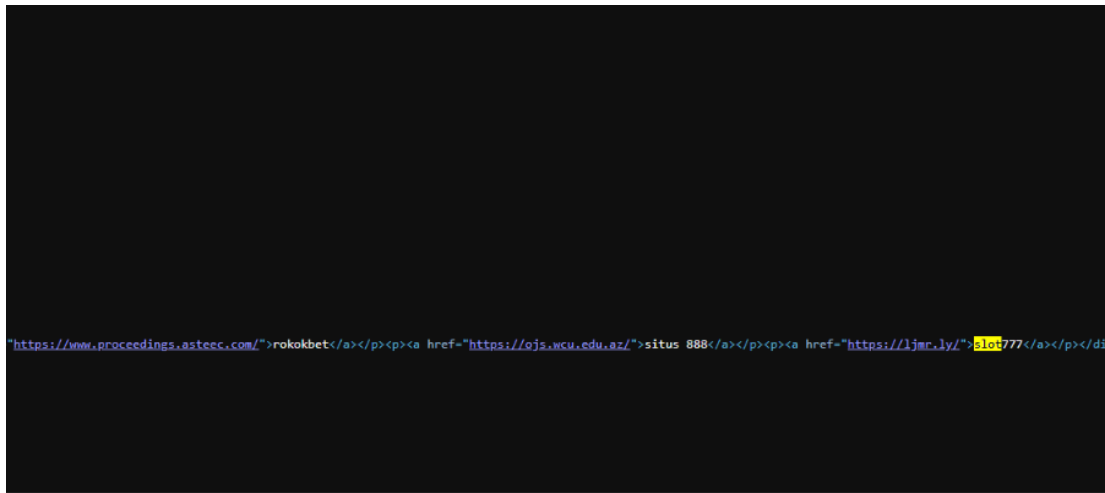


Gambar 3.8 Tampilan Inspect Element

Pada tab Elements, ditemukan blok kode `<div style="position: absolute; left: -9999px; ...">`. Teknik ini sengaja digunakan untuk menyembunyikan teks dari pandangan mata pengguna normal, namun tetap dapat dipindai oleh crawler mesin pencari untuk keperluan SEO pihak penyerang.

C. Link Profiling (Analisis Jaringan Tautan)

Tahap terakhir adalah mengidentifikasi seluruh daftar tautan yang disisipkan secara ilegal guna memetakan luasnya dampak link farm. Metodenya adalah menggunakan fitur view-source untuk melihat kode mentah HTML tanpa rendering CSS.



Gambar 3.9 Analisis kode sumber mentah

Penjelasan Hasil: Melalui pencarian kata kunci "slot" pada kode sumber, ditemukan puluhan tautan yang mengarah ke domain luar. Selain situs judi langsung (seperti slot777), ditemukan juga tautan menuju domain institusi lain seperti himpsipalu.org, kadinprovjakarta.id, hingga jurnal internasional lain. Hal ini menunjukkan bahwa sistem target telah menjadi bagian dari jaringan backlink ilegal internasional.

3.6.2 Kesimpulan Eksplorasi Pengerjaan SEO Spam Detection

Berdasarkan seluruh hasil pengujian di atas, dapat disimpulkan bahwa portal iptek.its.ac.id telah mengalami serangan SEO Spamming dan Journal Jacking yang terorganisir. Penyerang memanfaatkan celah pada platform OJS (diduga akibat penggunaan versi legacy yang tidak diperbarui) untuk menyisipkan daftar tautan massal menggunakan teknik manipulasi CSS tersembunyi. Dampaknya, kredibilitas akademik domain ITS tercemar oleh konten perjudian daring pada hasil pencarian publik.

BAB IV

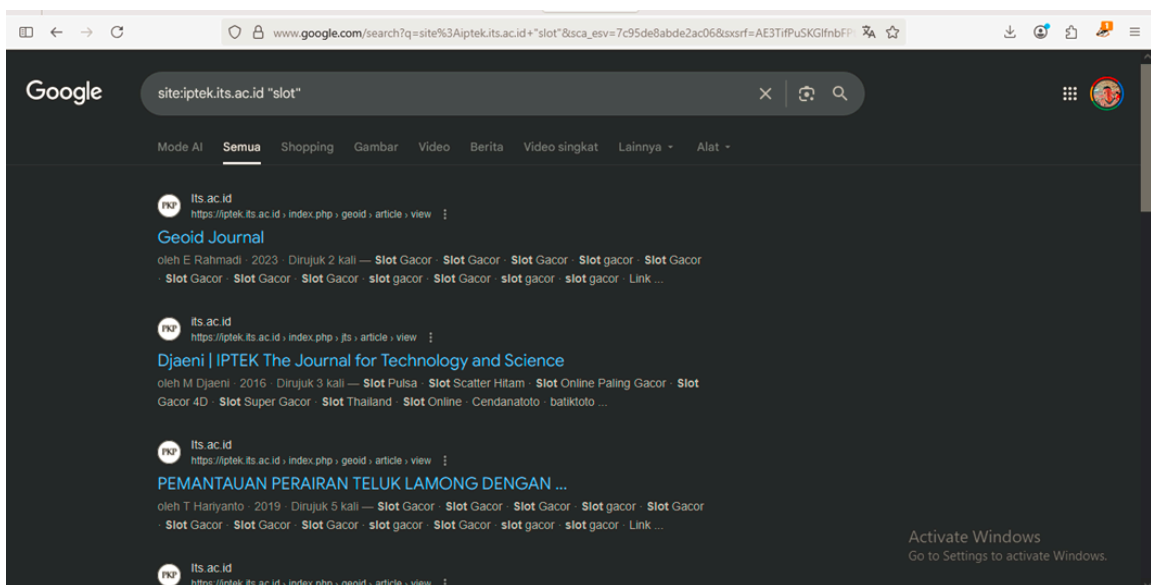
HASIL DAN PEMBAHASAN

4.1 Hasil Reconnaissance

Berdasarkan metodologi yang telah dijelaskan pada Bab III, berikut adalah hasil temuan dari tahap pengumpulan informasi awal terhadap target iptek.its.ac.id.

4.1.1 Temuan Google Dorking (Indikasi SEO Spam)

Pengujian menggunakan teknik Google Dorking dengan kata kunci spesifik perjudian (slot) menghasilkan temuan yang kritikal. Mesin pencari Google menampilkan sejumlah besar halaman jurnal di domain iptek.its.ac.id yang judul dan deskripsinya (meta description) telah berubah menjadi promosi situs judi daring.



Gambar 4.1 Hasil Pencarian Google menunjukan Indeks Jurnal yang Tersusupi Iklan Judi

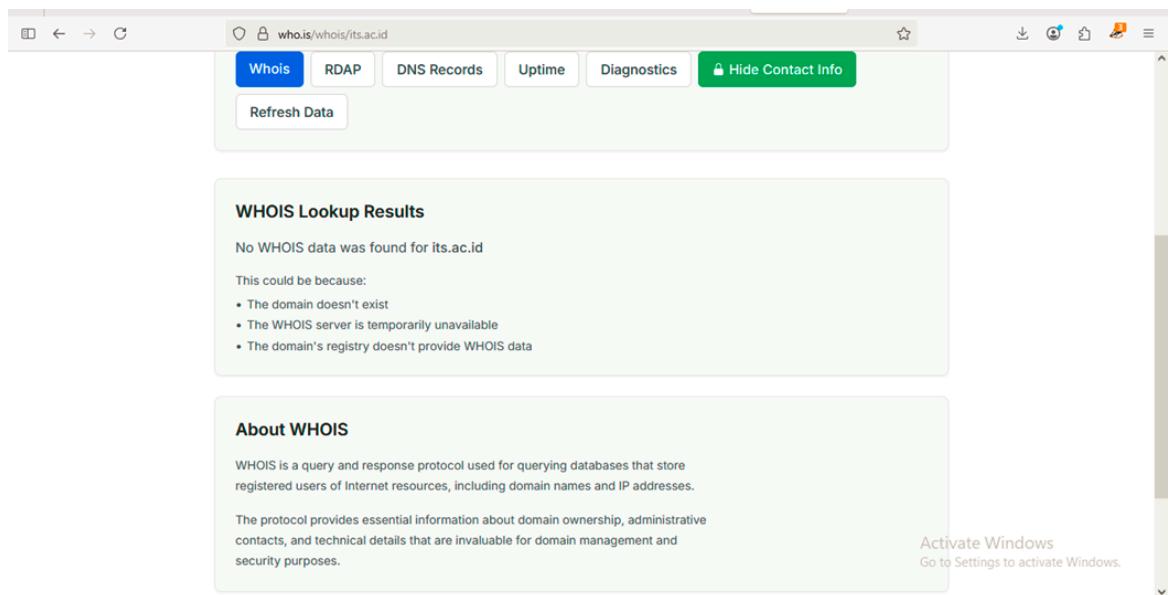
Sebagaimana terlihat pada Gambar 4.1, hasil pencarian menunjukkan tautan menuju jurnal resmi namun dengan deskripsi yang memuat teks promosi perjudian seperti "Cendanatoto", "Kapitalslot", "Batiktoto", dan "Slot Thailand". Hal ini mengindikasikan bahwa:

- Website telah mengalami serangan Journal Jacking atau SEO Spamming.
- Penyerang berhasil menyuntikkan konten ke dalam metadata OJS yang kemudian di-crawl oleh Google.

- Reputasi akademik domain ITS tercemar karena dikaitkan dengan konten ilegal.

4.1.2 Hasil Whois Lookup

Pemeriksaan Whois dilakukan untuk mengidentifikasi informasi registrasi domain. Meskipun beberapa informasi detail disembunyikan karena kebijakan privasi registrar domain akademik (.ac.id), alat pemindai mengonfirmasi keberadaan domain tersebut.



Gambar 4.2 Proses Pengecekan Informasi Whois Domain

4.1.3 Analisis Robots.txt

Pemeriksaan pada file <https://iptek.its.ac.id/robots.txt> menunjukkan konfigurasi standar OJS. File ini mendefinisikan aturan bagi search engine crawler.



Activate Windows
Go to Settings to activate Windows.

Gambar 4.3 Konfigurasi file Robots.txt yang terekspos

Meskipun file ini ada, tidak ditemukan aturan spesifik yang memblokir bot spam atau crawler jahat. Konfigurasi yang terlalu umum (User-agent: *) membiarkan bot mesin pencari mengindeks halaman-halaman yang telah disusupi spam tersebut.

4.2 Hasil Port Scanning (Nmap).

4.2.1 Hasil Basic Scan & Service Version

Berdasarkan pemindaian awal menggunakan teknik *Stealth Scan*, teridentifikasi bahwa target memiliki kebijakan keamanan jaringan yang cukup ketat di mana 997 port berada dalam status *filtered* (no-response). Namun, pemindaian berhasil mengidentifikasi port-port kritis yang terbuka sebagai berikut:

Komponen Pengujian	Hasil Temuan	Status/Kategori
Port Terbuka	80 (HTTP), 443 (HTTPS)	Open
Port Tertutup	8080 (HTTP-Proxy)	Closed

Melalui analisis file robots.txt, ditemukan direktori yang dilarang untuk diindeks yaitu /cache/.

```

C:\Users\DANIEL>nmap --script http-methods --script-args http-methods.url-path=/cache/ iptek.its.ac.id
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-19 19:10 SE Asia Standard Time
Nmap scan report for iptek.its.ac.id (202.46.129.184)
Host is up (0.064s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
|_ http-methods:
|_ Path tested: /cache/
443/tcp    open  https
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS TRACE
|_ Potentially risky methods: TRACE
|_ Path tested: /cache/
8080/tcp   closed http-proxy

```

Gambar 4.4 Hasil Nmap pada salah satu route

Pengujian lebih lanjut menggunakan skrip `http-methods` pada direktori tersebut menunjukkan bahwa port 443 mendukung metode TRACE, yang secara teknis berpotensi disalahgunakan untuk serangan *Cross-Site Tracing* (XST).

4.2.2 Hasil Aggressive Scan

Tahap pemindaian menggunakan Nmap `-A` menunjukkan hasil lebih representatif

```

TRACEROUTE (using port 8080/tcp)
HOP RTT      ADDRESS
1   5.00 ms   10.30.244.186
2   ... 3
4   74.00 ms  114.0.212.33
5   ...
6   79.00 ms  114-0-124-187.resources.indosat.com (114.0.124.187)
7   82.00 ms  114.9.20.12
8   ... 9
10  103.00 ms 202.46.129.184

```

Gambar 4.5 Hasil Nmap TRACEROUTE

Koneksi menuju server melewati 10 jaringan, ini menunjukkan adanya kebocoran informasi port 80 dan 443. Selain itu Nmap berhasil menebak OS yang digunakan pada server adalah sebagai berikut.

```

8080/tcp closed http-proxy
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X (97%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
Aggressive OS guesses: Linux 3.11 - 4.9 (97%), Linux 3.2 - 3.8 (92%), Linux 3.10 (88%), Linux 4.19 - 5.15 (88%)

```

Gambar 4.6 Hasil Nmap Os Guess

Dimana Linux versi 3.11 menjadi tebakan dari hasil packet yang dikirimkan Nmap pada server tersebut. Adapun hasil Keseluruhan Port scanning adalah sebagai berikut:

Komponen Pengujian	Hasil Temuan	Status/Kategori
Port Terbuka	80 (HTTP), 443 (HTTPS)	Open
Port Tertutup	8080 (HTTP-Proxy)	Closed
Layanan Luar	nginx 1.10.3	Outdated (High Risk)
Layanan Backend	Apache 2.2.15 (CentOS)	Outdated (Critical)
Sistem Operasi	Linux (Kernel 3.11 - 5.15)	Detected (97%)
Metode HTTP	TRACE Enabled (Port 443)	Risky Method

4.3 Hasil Directory Scanning (Gobuster)

4.3.1 Hasil Enumerasi Direktori

Pada tahap ini, dilakukan pemindaian direktori terhadap target <https://iptek.its.ac.id> menggunakan dua jenis *wordlist* berbeda untuk membandingkan efektivitas dan kedalaman temuan.

```
.perf (Status: 403) [Size: 169]
cache (Status: 301) [Size: 319] [--> http://iptek.its.ac.id/cache/]
cgi-bin/ (Status: 403) [Size: 291]
classes (Status: 301) [Size: 321] [--> http://iptek.its.ac.id/classes/]
controllers (Status: 301) [Size: 325] [--> http://iptek.its.ac.id/controllers/]
dbadmin (Status: 301) [Size: 321] [--> http://iptek.its.ac.id/dbadmin/]
docs (Status: 301) [Size: 318] [--> http://iptek.its.ac.id/docs/]
favicon.ico (Status: 200) [Size: 1150]
help (Status: 301) [Size: 318] [--> http://iptek.its.ac.id/help/]
js (Status: 301) [Size: 316] [--> http://iptek.its.ac.id/js/]
index.php (Status: 200) [Size: 142931]
lib (Status: 301) [Size: 317] [--> http://iptek.its.ac.id/lib/]
locale (Status: 301) [Size: 320] [--> http://iptek.its.ac.id/locale/]
node_modules/.package-lock.json (Status: 403) [Size: 169]
pages (Status: 301) [Size: 319] [--> http://iptek.its.ac.id/pages/]
plugins (Status: 301) [Size: 321] [--> http://iptek.its.ac.id/plugins/]
public (Status: 301) [Size: 320] [--> http://iptek.its.ac.id/public/]
robots.txt (Status: 200) [Size: 31]
styles (Status: 301) [Size: 320] [--> http://iptek.its.ac.id/styles/]
templates (Status: 301) [Size: 323] [--> http://iptek.its.ac.id/templates/]
tools (Status: 301) [Size: 319] [--> http://iptek.its.ac.id/tools/]
Progress: 4750 / 4750 (100.00%)
=====
Finished
=====
```

Gambar 4.7 Hasil directory scanning menggunakan wordlist common.txt


```

=====
Starting gobuster in directory enumeration mode
=====
help                (Status: 301) [Size: 318] [--> http://iptek.its.ac.id/help/]
templates           (Status: 301) [Size: 323] [--> http://iptek.its.ac.id/templates/]
docs                (Status: 301) [Size: 318] [--> http://iptek.its.ac.id/docs/]
tools               (Status: 301) [Size: 319] [--> http://iptek.its.ac.id/tools/]
pages               (Status: 301) [Size: 319] [--> http://iptek.its.ac.id/pages/]
public              (Status: 301) [Size: 320] [--> http://iptek.its.ac.id/public/]
plugins             (Status: 301) [Size: 321] [--> http://iptek.its.ac.id/plugins/]
lib                 (Status: 301) [Size: 317] [--> http://iptek.its.ac.id/lib/]
js                  (Status: 301) [Size: 316] [--> http://iptek.its.ac.id/js/]
cache               (Status: 301) [Size: 319] [--> http://iptek.its.ac.id/cache/]
classes             (Status: 301) [Size: 321] [--> http://iptek.its.ac.id/classes/]
styles              (Status: 301) [Size: 320] [--> http://iptek.its.ac.id/styles/]
registry            (Status: 301) [Size: 322] [--> http://iptek.its.ac.id/registry/]
rt                  (Status: 301) [Size: 316] [--> http://iptek.its.ac.id/rt/]
locale              (Status: 301) [Size: 320] [--> http://iptek.its.ac.id/locale/]
controllers         (Status: 301) [Size: 325] [--> http://iptek.its.ac.id/controllers/]
Progress: 65808 / 1273830 (5.17%) [ERROR] error on word 10644: Get "https://iptek.its.ac.i
k.its.ac.id: no such host
dbadmin             (Status: 301) [Size: 321] [--> http://iptek.its.ac.id/dbadmin/]
public              (Status: 301) [Size: 320] [--> http://iptek.its.ac.id/public/]
Progress: 1273830 / 1273830 (100.00%)
=====
Finished
=====

```

Gambar 4.8 Hasil directory scanning menggunakan wordlist directory-list-2.3-big.txt

Berdasarkan hasil pemindaian pada Gambar 4.1 dan Gambar 4.2, ditemukan sejumlah direktori dengan kode status HTTP 200 (OK) dan 301 (Moved Permanently). Rangkuman komparasi hasil temuan antara kedua *wordlist* disajikan pada Tabel 4.1 berikut:

No	Nama Direktori	Status	common.txt	Big Wordlist?	Keterangan Potensial
1	/dbadm in	301	Ada	Ada	Panel Admin Database (Kritis)
2	/tools	301	Ada	Ada	Utilitas Pengembangan/Testing
3	/classes	301	Ada	Ada	Struktur Backend (MVC)
4	/controll ers	301	Ada	Ada	Struktur Backend (MVC)

5	/registry	301	Tidak Ada	Ada	Konfigurasi Sistem (OJS)
6	/rt	301	Tidak Ada	Ada	<i>Reading Tools</i> (Fitur OJS)
7	/robots.txt	200	Ada	Ada	File konfigurasi Crawler
8	/plugins	301	Ada	Ada	Modul tambahan aplikasi

4.3.2 Analisis Perbandingan Wordlist

Hasil pengujian menunjukkan perbedaan signifikan antara penggunaan wordlist standar dan wordlist skala besar. Wordlist common.txt berhasil mengidentifikasi direktori umum seperti /admin, /public, dan struktur dasar framework (/classes, /controllers).

Namun, penggunaan directory-list-2.3-big.txt memberikan hasil yang lebih mendalam dengan ditemukannya direktori /registry dan /rt. Direktori ini tidak terdeteksi oleh wordlist standar karena penamaannya yang spesifik terhadap platform tertentu dan bukan merupakan nama direktori umum. Hal ini membuktikan bahwa penggunaan wordlist yang lebih komprehensif sangat krusial dalam menemukan aset tersembunyi yang spesifik pada aplikasi target.

4.3.3 Identifikasi Platform (Fingerprinting)

Berdasarkan korelasi antar-direktori yang ditemukan, dapat dilakukan proses *fingerprinting* untuk mengidentifikasi jenis aplikasi yang berjalan di server.

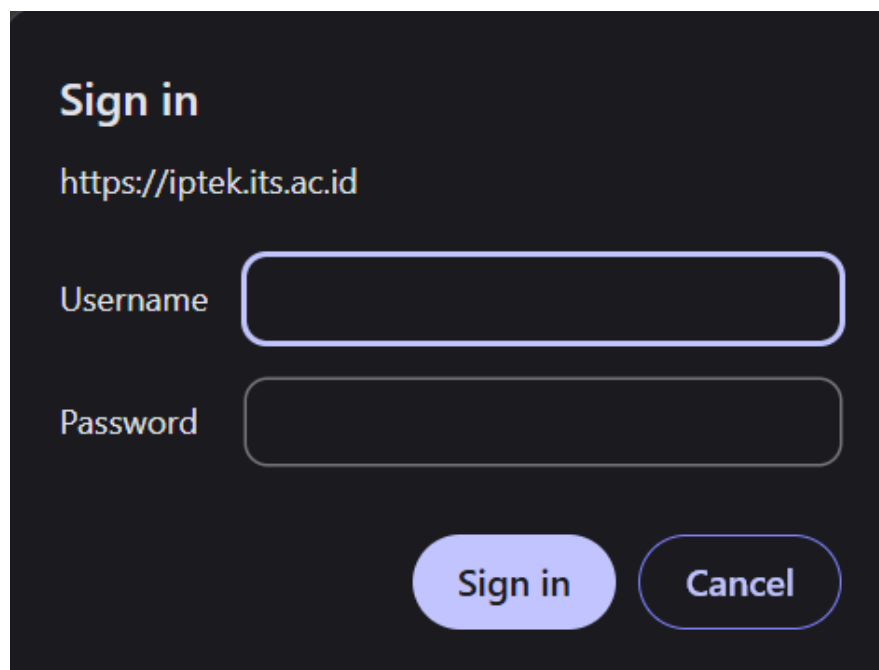
1. Keberadaan direktori /classes, /controllers, /templates, dan /lib mengindikasikan bahwa aplikasi dibangun menggunakan arsitektur *Model-View-Controller* (MVC) berbasis PHP.
2. Penemuan direktori spesifik /rt (*Reading Tools*) dan /registry, dikombinasikan dengan struktur /plugins dan /locale, merupakan karakteristik unik dari *Content Management System* (CMS) Open Journal

Systems (OJS), khususnya varian versi 2.x. Identifikasi ini penting karena memungkinkan pengujian untuk memetakan potensi kerentanan spesifik (CVE) yang melekat pada versi OJS tersebut.

4.3.4 Analisis Temuan Kritis dan Validasi Manual

Dari seluruh direktori yang ditemukan, terdapat dua *endpoint* yang memiliki risiko keamanan tertinggi dan memerlukan validasi manual melalui peramban (*browser*).

- Analisis Direktori ini memberikan respons 301 yang mengarah ke halaman login atau panel pengelolaan basis data. Jika direktori ini dapat diakses oleh publik tanpa pembatasan IP (*IP Whitelisting*), hal ini merupakan celah keamanan kategori *Information Disclosure* yang berisiko tinggi. Penyerang dapat memanfaatkan halaman ini untuk melakukan serangan *Brute Force* terhadap kredensial basis data.

The image shows a dark-themed web interface for a sign-in page. At the top, the text 'Sign in' is displayed in a light blue font. Below it, the URL 'https://iptek.its.ac.id' is shown in a smaller, light blue font. There are two input fields: 'Username' and 'Password', both with light blue borders. At the bottom right, there are two buttons: 'Sign in' and 'Cancel', both with a light blue gradient and rounded corners.

Gambar 4.9 Validasi akses ke direktori /dbadmin

- Validasi manual terhadap direktori /tools/ menghasilkan respons kode status HTTP 403 Forbidden. Respons ini mengindikasikan bahwa meskipun direktori tersebut eksis di server, administrator telah menonaktifkan fitur *Directory Listing*, sehingga isi direktori tidak dapat dilihat oleh publik.

Forbidden

You don't have permission to access /tools/ on this server.

Apache/2.2.15 (CentOS) Server at iptek.its.ac.id Port 80

Gambar 4.10 Validasi akses ke direktori /tools/

4.3.5 Hasil Enumerasi Rekursif (Recursive Scanning)

Untuk menindaklanjuti temuan direktori /dbadmin pada tahap sebelumnya, dilakukan pemindaian rekursif guna mengidentifikasi isi konten di dalamnya.

```
.web (Status: 403) [Size: 169]
.svnignore (Status: 403) [Size: 169]
examples (Status: 301) [Size: 330] [--> http://iptek.its.ac.id/dbadmin/examples/]
favicon.ico (Status: 200) [Size: 18902]
index.php (Status: 401) [Size: 988]
js (Status: 301) [Size: 324] [--> http://iptek.its.ac.id/dbadmin/js/]
libraries (Status: 403) [Size: 300]
locale (Status: 301) [Size: 328] [--> http://iptek.its.ac.id/dbadmin/locale/]
node_modules/.package-lock.json (Status: 403) [Size: 169]
phpinfo.php (Status: 401) [Size: 988]
setup (Status: 301) [Size: 327] [--> http://iptek.its.ac.id/dbadmin/setup/]
themes (Status: 301) [Size: 328] [--> http://iptek.its.ac.id/dbadmin/themes/]
Progress: 4750 / 4750 (100.00%)
```

Gambar 4.11 Hasil Enumerasi Rekursif pada Direktori /dbadmin

Gambar 4.11 menunjukkan hasil enumerasi sub-direktori. Berdasarkan hasil tersebut, ditemukan dua *endpoint* spesifik yang sangat berisiko, yaitu direktori /setup/ dan file phpinfo.php. Berikut adalah analisis mendalam dan validasi terhadap kedua temuan rekursif tersebut:

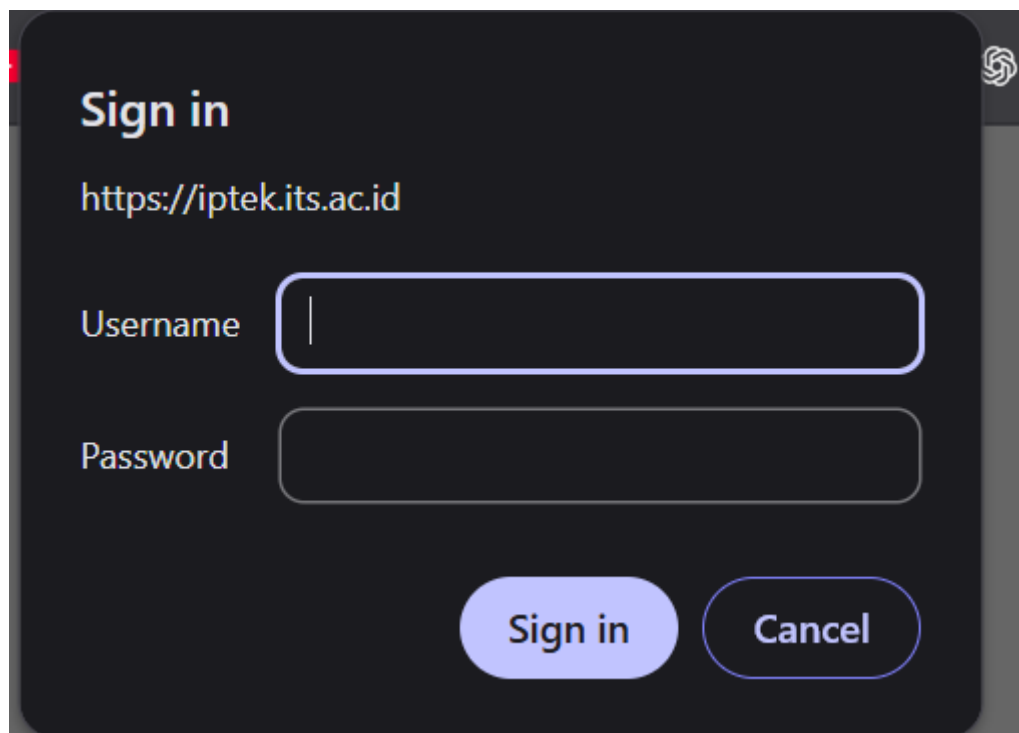
1. Direktori /dbadmin/setup/ Direktori ini teridentifikasi sebagai halaman konfigurasi instalasi phpMyAdmin. Validasi manual dilakukan dengan mengakses URL tersebut (lihat Gambar 4.9 di bawah).



Gambar 4.12 Hasil Validasi ke direktori /dbadmin/setup

Analisisnya adalah terbukanya halaman setup ini merupakan kerentanan Critical (Kategori Security Misconfiguration). Halaman ini memungkinkan pengguna tanpa otentikasi untuk memanipulasi konfigurasi koneksi database server. Hal ini membuktikan bahwa administrator lalai menghapus direktori instalasi pasca-implementasi.

2. File /dbadmin/phpinfo.php File ini ditemukan dengan kode status 401. Validasi manual (Gambar 4.b) menunjukkan adanya proteksi Basic Authentication.



Gambar 4.13 Sign in https://iptek.its.ac.id

Analisisnya adalah Meskipun dilindungi password, keberadaan file debugging seperti phpinfo.php di lingkungan produksi tetap melanggar prinsip keamanan (*Hardening*). Jika otentikasi ini ditembus, penyerang akan mendapatkan informasi lengkap mengenai versi PHP dan modul server (*Information Disclosure*)."

4.4 Analisis Celah Keamanan Aplikasi

4.4.1 Temuan SEO Spam pada Metadata Jurnal

Berdasarkan hasil asesmen keamanan yang dilakukan melalui teknik Google Dorking dan Source Code Inspection, ditemukan bukti konkret adanya aktivitas SEO Spam dan Journal Jacking pada portal iptek.its.ac.id. Serangan ini secara spesifik menargetkan metadata artikel jurnal guna menyisipkan konten ilegal yang tidak relevan dengan aktivitas akademik.

A. Analisis Teknik Serangan (Hidden Link Injection)

Analisis teknis terhadap halaman artikel Geoid Journal mengungkap bahwa penyerang menggunakan metode CSS Hidden Text untuk memanipulasi indeks mesin pencari.

- Penyerang menyisipkan tag <div> dengan atribut style position: absolute; left: -9999px; top: -9999px; overflow: hidden;. Penggunaan koordinat negatif yang ekstrem ini memastikan bahwa teks spam tidak akan terlihat oleh pengunjung jurnal di browser, namun tetap dapat dipindai oleh robot pengindeks mesin pencari.
- Penyerang memanfaatkan celah pada platform Open Journal Systems (OJS) versi lawas (Legacy 2.x) yang memiliki validasi input lemah pada bagian deskripsi jurnal atau metadata artikel. Hal ini memungkinkan karakter HTML mentah dieksekusi dan disimpan secara permanen di dalam basis data sistem.

B. Profiling Jaringan Link Farm

Ditemukan bahwa portal target tidak hanya digunakan untuk mempromosikan situs judi, tetapi juga dijadikan bagian dari jaringan Link Farm atau Private Blog Network (PBN). Berikut adalah rincian kategori beberapa tautan yang ditemukan:

Kategori Tautan	Contoh Domain yang Ditemukan	Tujuan Serangan
Konten Ilegal	slot777, rokokbet, situs 888	Promosi langsung situs perjudian daring guna meningkatkan traffic.
Situs Institusi	himpsipalu.org, kadinprovjakarta.id, pafidesapancoranmas.org	Membangun profil backlink yang terlihat "alami" dengan mencampur situs resmi yang juga telah dibajak.
Jurnal Akademik	scientiamilitaria.journals.a c.za, udayannursingcollege.edu. bd	Memanfaatkan reputasi domain akademik (EDID/ACID) untuk menaikkan otoritas SEO jaringan spam.

C. Analisis Risiko dan Dampak

Dampak dari temuan ini sangat signifikan terhadap integritas aset informasi ITS, antara lain:

- Munculnya kata kunci perjudian pada hasil pencarian jurnal ilmiah di Google secara langsung mencoreng citra Institut Teknologi Sepuluh Nopember sebagai institusi teknik terkemuka.
- Algoritma Google dapat menandai domain its.ac.id sebagai situs berbahaya atau sarang spam, yang berpotensi menyebabkan seluruh konten jurnal tidak muncul lagi dalam hasil pencarian publik.
- Keberhasilan penyerang dalam memodifikasi konten tanpa izin menunjukkan adanya celah pada kontrol akses aplikasi yang dapat berkembang menjadi serangan lebih serius terhadap data internal lainnya.

D. Rekomendasi Mitigasi Teknis

Untuk memulihkan integritas portal iptek.its.ac.id, disarankan langkah-langkah perbaikan sebagai berikut:

- Melakukan audit dan sanitasi manual pada tabel `article_settings` dan `journal_settings` di basis data OJS untuk menghapus seluruh blok kode tersembunyi.
- Segera mempercepat proses migrasi dari Legacy OJS 2 ke OJS 3 yang memiliki mekanisme sanitasi input dan proteksi metadata yang lebih modern.
- Mengkonfigurasi Web Application Firewall (WAF) untuk memblokir permintaan yang mengandung kata kunci spam populer dan memperketat izin akses tulis (file permission) pada direktori publik server.

4.4.2 Analisis Versi OJS (Outdated Version)

Berdasarkan hasil inspeksi manual pada kode sumber (*source code*) portal iptek.its.ac.id, ditemukan bahwa platform yang digunakan adalah Open Journal Systems (OJS) versi 2.4.2.0. Berdasarkan standar keamanan perangkat lunak, versi ini dikategorikan sebagai *legacy/outdated software* yang sudah tidak mendapatkan dukungan pembaruan keamanan resmi. Selain platform utama, pemeriksaan pada *header respons* server menunjukkan penggunaan teknologi pendukung yang juga sudah mencapai masa akhir dukungan (*End-of-Life*), yaitu:

- Web Server: nginx/1.10.3 dan Apache/2.2.15.
- Bahasa Pemrograman: PHP/5.3.3.
- Library JavaScript: jQuery v1.4.4 dan jQuery UI 1.8.6.

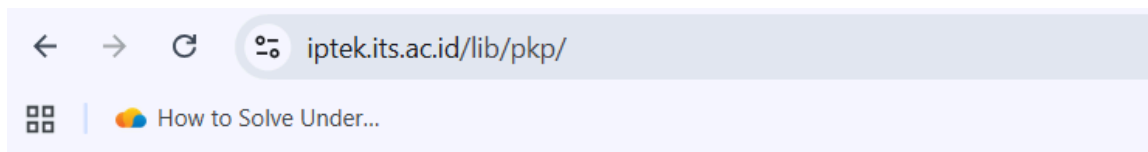
Penggunaan PHP 5.3.3 ditemukan memiliki kerentanan kritis dengan skor CVSS 10.0 (misalnya CVE-2012-2688). Kelemahan ini memungkinkan penyerang melakukan eksekusi kode jarak jauh atau menyebabkan kegagalan sistem secara total. jQuery 1.4.4: Teridentifikasi memiliki kerentanan CVE-2020-11022 dan CVE-2020-11023 terkait serangan *Cross-Site Scripting* (XSS).

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
  <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
  <title>Open Journal Systems</title>
  <meta name="description" content="" />
  <meta name="keywords" content="" />
  <meta name="generator" content="Open Journal Systems 2.4.2.0" />

```

Name	X	Headers	Preview	Response	Initiator	Timing	Cookies
iptek.its.ac.id		Cache-Control		public			
pkp.css	✓	Connection		keep-alive			
common.css	✓	Content-Encoding		gzip			
common.css	✓	Content-Type		text/html; charset=utf-8			
compiled.css	✓	Date		Fri, 19 Dec 2025 05:22:53 GMT			
jquery.min.js	ⓧ	Server		nginx/1.10.3			
jqueryUi.min.js	ⓧ	Transfer-Encoding		chunked			
sidebar.css	✓	X-Frame-Options		SAMEORIGIN			
rightSidebar.css	✓	X-Powered-By		PHP/5.3.3			

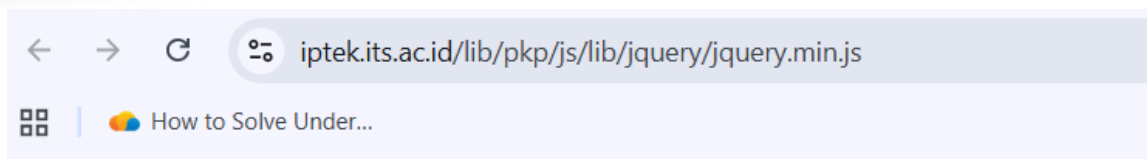
178 requests | 6.4 MB



Forbidden

You don't have permission to access /lib/pkp/ on this server.

Apache/2.2.15 (CentOS) Server at iptek.its.ac.id Port 80



```
/*!
 * jQuery JavaScript Library v1.4.4
 * http://jquery.com/
 *
 * Copyright 2010, John Resig
 * Dual licensed under the MIT or GPL Version 2 licenses.
 * http://jquery.org/license
 *
 * Includes Sizzle.js
 * http://sizzlejs.com/
 * Copyright 2010, The Dojo Foundation
 * Released under the MIT, BSD, and GPL Licenses.
 *
 * Date: Thu Nov 11 19:04:53 2010 -0500
 */
(function( window, undefined ) {
```

Penggunaan komponen usang ini sangat berisiko karena memiliki berbagai celah keamanan kritis yang telah terdaftar di basis data publik, seperti kerentanan eksekusi kode jarak jauh (RCE) dan kebocoran informasi.

4.4.3 Pengujian Halaman Login

Pengujian dilakukan untuk mengevaluasi ketahanan mekanisme login terhadap berbagai vektor serangan umum. Berikut adalah temuan-temuan kritis:

1. Ketidadaan Token Anti-CSRF (Cross-Site Request Forgery)

Hasil inspeksi terhadap kode HTML pada elemen `<form id="signInForm">` menunjukkan bahwa portal tidak menerapkan token keamanan unik (CSRF Token). Di dalam formulir hanya terdapat input untuk source, username, dan password.

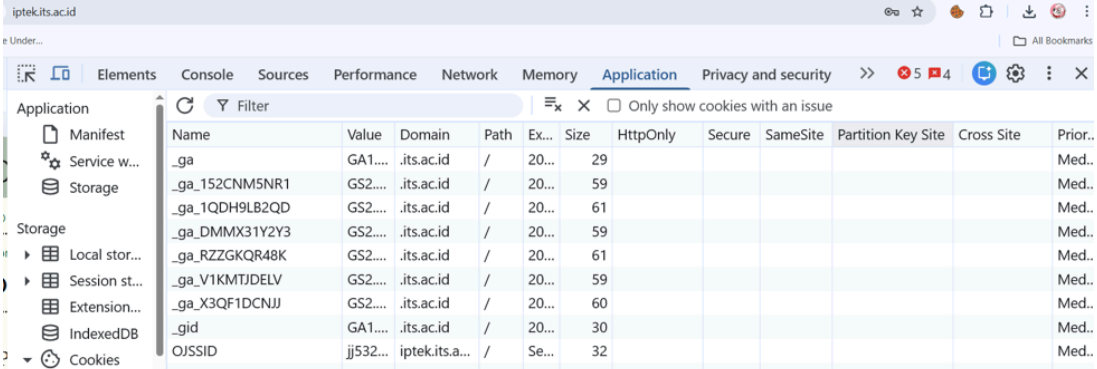
Dampaknya adalah penyerang dapat membuat halaman jebakan yang memaksa peramban pengguna untuk mengirimkan permintaan tidak sah ke server ITS seolah-olah permintaan tersebut datang dari pengguna yang sah. Hal ini dibuktikan dengan struktur tag `<form>` yang hanya memuat input username, password, dan tombol login tanpa adanya token keamanan acak (anti-CSRF token)

```
<form id="signinForm" method="post" action="https://iptek.its.ac.id/index.php/jts/login/signIn">
```

2. Keamanan Cookie Sesi yang Lemah (Missing HttpOnly & Secure Flag)

Melalui pemeriksaan pada cookie sesi OJSSID, ditemukan bahwa sistem tidak menyertakan flag HttpOnly dan Secure. Dampaknya adalah tanpa flag HttpOnly, ID sesi dapat dicuri melalui serangan Cross-Site Scripting (XSS). Tanpa flag Secure, ID sesi dikirimkan dalam bentuk teks biasa jika pengguna mengakses melalui jalur non-HTTPS, sehingga rentan terhadap penyadapan (eavesdropping).

Kelemahan Atribut Cookie Sesi Inspeksi terhadap cookie sesi OJSSID menunjukkan ketiadaan flag keamanan HttpOnly dan Secure. Hal ini membuktikan bahwa sesi pengguna rentan terhadap serangan pencurian sesi (*Session Hijacking*) melalui skrip berbahaya dan penyadapan pada jalur yang tidak terenkripsi.



Name	Value	Domain	Path	Ex...	Size	HttpOnly	Secure	SameSite	Partition Key Site	Cross Site	Prior..
._ga	GA1...	.its.ac.id	/	20...	29						Med..
._ga_152CNM5NR1	GS2...	.its.ac.id	/	20...	59						Med..
._ga_1QDH9LB2QD	GS2...	.its.ac.id	/	20...	61						Med..
._ga_DMMX31Y2Y3	GS2...	.its.ac.id	/	20...	59						Med..
._ga_RZZGKQR48K	GS2...	.its.ac.id	/	20...	61						Med..
._ga_V1KMTJDELV	GS2...	.its.ac.id	/	20...	59						Med..
._ga_X3QF1DCNJJ	GS2...	.its.ac.id	/	20...	60						Med..
._gid	GA1...	.its.ac.id	/	20...	30						Med..
OJSSID	jj532...	iptek.its.a...	/	Se...	32						Med..

3. Insecure Form Transition Analisis menunjukkan adanya transisi data yang tidak aman, di mana halaman login yang diakses melalui protokol HTTP (tidak aman) mengirimkan data kredensial ke alamat tujuan HTTPS. Dampaknya adalah membuka celah serangan Man-in-the-Middle (MITM) di mana penyerang dapat memanipulasi formulir sebelum enkripsi HTTPS aktif. Kerentanan ini terjadi ketika sebuah halaman yang tidak aman (HTTP) mengirimkan data sensitif ke alamat yang aman (HTTPS).

```

"blockTitle" href="http://pkp.sfu.ca/ojs/" id="developedBy">Open Journal Systems</a>
ass="block" id="sidebarHelp">
"blockTitle" href="javascript:openHelp('https://iptek.its.ac.id/index.php/index/help/view/user/topic/000003')">Jou
ass="block" id="sidebarUser">
span class="blockTitle">User</span>

<form method="post" action="https://iptek.its.ac.id/index.php/index/login/signIn">
<table>
<tr>
<td><label for="sidebar-username">Username</label></td>
<td><input type="text" id="sidebar-username" name="username" value="" size="12" maxlength="32" class="f

```

4. Eksposur Informasi Internal (Private IP Disclosure) Ditemukan kebocoran informasi alamat IP internal jaringan (192.168.10.10) di dalam kode sumber halaman. Informasi ini sangat sensitif karena memberikan gambaran mengenai topologi jaringan internal kepada pihak luar.

```

→ ↺ ⓘ view-source:https://iptek.its.ac.id/index.php/limits/article/view/3489
How to Solve Under...

<br />
<div>
<p>G. Chowell, P.W. Fenimore, M. A. Castillo-Grasow, and C. Castillo
<p>A. B. Gumel, S. Ruan, T. Day, J. Watmough, F. Brauer, P. Van Den I
<p>A. Naheed, M. Singh, and D. Lucy, Numerical Study of SARS Epidemi
<p>W. E. Schiesser, and G. W. Griffiths, A Compendium of Partial Diffi
<p>J. Serradell, Deadly Diseases and Epidemic SARS Second Edition, Cl
<p>WHO, SARS: How a global epidemic was stopped, WHOPress: Western P
<p>J. L. Xia, C. Yao, and G. K. Zhang, Analysis of Piecewise Comparti
</div>
<br />
</div>

<br />
<br />
DOI: <a id="pub-id::doi" href="http://dx.doi.org/10.12962%2Flimits.v15i1.3489">http://dx

<div class="separator"></div>

<h3>Refbacks</h3>

<ul class="plain">
<li>&#187; <a href="http://192.168.10.10/bo/records?archive_id=600" target="_parent"
<li>&#187; <a href="http://arjuna.ristekdikti.go.id/index.php/myarticles/daftar_usul

```


BAB V

KESIMPULAN DAN SARAN

5.1 Kesimpulan

Berdasarkan serangkaian pengujian keamanan (Vulnerability Assessment) dan analisis temuan yang telah dilakukan terhadap portal jurnal iptek.its.ac.id, dapat ditarik beberapa kesimpulan krusial:

1. Sistem Terkompromi (Compromised)

Website iptek.its.ac.id telah positif mengalami insiden keamanan kategori SEO Spamming atau Journal Jacking. Ditemukan ratusan indeks halaman jurnal resmi ITS di mesin pencari Google yang metadata deskripsinya telah dimanipulasi memuat kata kunci perjudian daring seperti "Slot Gacor", "Cendanatoto", dan "Situs 888".

2. Penyebab Utama (Root Cause)

Celah keamanan utama bersumber dari penggunaan platform Open Journal Systems (OJS) versi lawas (2.x) yang sudah End-of-Life (tidak didukung lagi). Versi ini memiliki kerentanan bawaan pada fitur registrasi pengguna (Open Registration) yang lemah validasi, memungkinkan bot otomatis untuk membuat akun dan menyuntikkan konten spam.

3. Dampak Risiko (Risk Level)

Risiko dikategorikan sebagai HIGH (Tinggi). Meskipun tidak ada pengambilalihan server secara penuh (Root Access), serangan ini merusak integritas data publikasi dan mencemarkan reputasi akademik Institut Teknologi Sepuluh Nopember di mata publik dan mesin pencari.

5.2 Saran

Untuk memulihkan sistem dan mencegah serangan serupa, direkomendasikan langkah-langkah perbaikan sebagai berikut:

1. Pembersihan Database (Immediate Action):

- Administrator harus segera melakukan sanitasi database untuk menghapus akun-akun pengguna palsu (bot) dan membersihkan metadata artikel yang mengandung kata kunci spam perjudian.

- Mengajukan permintaan penghapusan indeks (URL Removal Request) melalui Google Search Console agar hasil pencarian yang berisi spam segera hilang dari Google.

2. Upgrade Sistem (Long-Term Solution):

- Sangat disarankan untuk segera melakukan migrasi sistem dari OJS 2.x ke OJS 3.3+ (LTS Release). Versi terbaru memiliki fitur keamanan yang jauh lebih baik, arsitektur kode yang lebih aman, dan dukungan komunitas aktif.

3. Pengerasan Keamanan (Hardening):

- Disable Open Registration: Menutup fitur pendaftaran terbuka untuk umum. Pendaftaran penulis sebaiknya dilakukan melalui undangan (Invitation Only) atau moderasi ketat.
- Implementasi CAPTCHA: Jika pendaftaran tetap harus dibuka, wajib menambahkan validasi Google reCAPTCHA v3 pada formulir registrasi dan login untuk memblokir bot spam.
- Web Application Firewall (WAF): Memasang WAF untuk memfilter trafik berbahaya dan memblokir upaya injeksi skrip (XSS/SQLi).

DAFTAR PUSTAKA

- CVE Details. (2025). PKP Open Journal Systems Vulnerability Statistics. Diakses dari <https://www.cvedetails.com/product/17584/PKP-Open-Journal-Systems.html>
- EC-Council. (2023). What is Penetration Testing? Phases & Types. Diakses dari <https://www.eccouncil.org/what-is-penetration-testing/>
- Imperva. (2024). What is Penetration Testing | Step-By-Step Process & Methods. Diakses dari <https://www.imperva.com/learn/application-security/penetration-testing/>
- OWASP Foundation. (2021). OWASP Top 10:2021. Diakses dari <https://owasp.org/Top10/>
- PKP Docs. (2023). Learning OJS 3: User Accounts and Registration. Diakses dari <https://docs.pkp.sfu.ca/learning-ojs/>
- PortSwigger. (2024). Web Security Academy: SQL Injection & Cross-site Scripting. Diakses dari <https://portswigger.net/web-security>
- Public Knowledge Project. (2024). Open Journal Systems. Diakses dari <https://pkp.sfu.ca/software/ojs/>
- Sucuri. (2023). What is SEO Spam? (Spamdexing). Diakses dari <https://blog.sucuri.net/tag/seo-spam>